

BOOTCAMP · YNOV MONTPELLIER

Cahier de TP

Cybersécurité, Pentest & AB Testing — Document de travail

À compléter en binôme au fil de la journée

Date : 17/09/2026 · Durée : 6 h

À remplir au fil de la journée

Cahier de TP — Bootcamp Cyber & AB Testing

Document de travail à compléter en binôme. Date : 17/09/2026.

Binôme — Prénom 1 : Prénom 2 :

Cible utilisée (entourez) : DVWA (Docker local) / Metasploitable 2 — IP de la cible :

 **RÈGLE D'OR — À LIRE AVANT DE COMMENCER** Tous les outils de ce cahier ne visent **QUE les machines virtuelles installées en local** sur votre ordinateur, dans le réseau isolé « host-only ». **Jamais** un site réel, la box internet, le réseau de l'école ou la machine d'un tiers. En dehors de ce cadre, c'est un **délit** (articles 323-1 et suivants du Code pénal). En cas de doute : demandez au formateur.

 **Comment travailler en binôme ?** L'un·e de vous **manipule**, l'autre **observe et note** dans ce cahier. **Inversez les rôles** à chaque TP. Notez tout ce que vous voyez, même ce que vous ne comprenez pas : on en discutera.

TP1 — Reconnaissance réseau (≈ 20 min)

Objectif : trouver la machine cible sur le réseau, puis dresser la liste de ses portes d'entrée (ports/services). C'est l'étape « repérage » d'un pentest.

Consignes pas-à-pas

Dans un terminal Kali, exécutez dans l'ordre :

1) Afficher sa propre adresse IP et le réseau (repérez l'interface, ex. eth1)
`ip a`

2) Découvrir les machines vivantes sur le réseau isolé
`nmap -sn 192.168.56.0/24`

3) Scan détaillé de la cible : tous les ports, services et versions
`nmap -sV -sC -p- <IP_CIBLE>`

💡 **Astuce** — Remplacez `<IP_CIBLE>` par l'adresse trouvée à l'étape 2. Le scan `-p-` (tous les ports) peut prendre quelques minutes : c'est normal.

Fiche de reconnaissance à compléter

Mon IP Kali : IP de la cible :

Port	État	Service	Version	Remarque

Questions de compréhension

1. Combien de ports ouverts avez-vous trouvés ?

2. Quel service vous semble le **plus risqué**, et pourquoi ?

3. En quoi cette liste illustre-t-elle la notion de « **surface d'attaque** » (voir cours § 2.1) ?

TP2 — Interception HTTP avec Burp Suite (≈ 15 min)

Objectif : voir « en vrai » ce que le navigateur envoie au serveur, pour comprendre qu'on peut tout lire et tout modifier.

Consignes pas-à-pas

1. Lancez **Burp Suite** dans Kali (menu → Web Application Analysis → Burp Suite). Acceptez le projet temporaire par défaut.
2. Onglet **Proxy** → **Intercept** : vérifiez que l'interception est sur « **Intercept is on** ».
3. Configurez le navigateur pour passer par le proxy Burp (**127.0.0.1:8080**) — utilisez le navigateur embarqué de Burp (bouton « **Open Browser** »), déjà préconfiguré.
4. Dans ce navigateur, ouvrez **DVWA** et connectez-vous (login **admin** / **password**). Naviguez vers un formulaire (ex. **Brute Force** ou **DVWA Login**).
5. Observez la requête **capturée** par Burp avant de l'envoyer (bouton **Forward** pour la laisser passer).

Zone d'observation

Recopiez la première ligne de la requête interceptée (ex. **GET /... HTTP/1.1**) :

Répondez :

- Méthode HTTP utilisée (GET ou POST) ?
- Quels **paramètres** voyez-vous passer ?
- Où apparaît le **mot de passe** ? Est-il visible en clair ?

🔑 **À retenir** — Tout ce qui part du navigateur peut être lu et modifié. C'est pourquoi un serveur ne doit **jamais faire confiance** aux données reçues (cours § 2.3).

TP3 — Injection SQL & XSS (≈ 25 min)

Contexte : DVWA, niveau de sécurité **Low** (onglet *DVWA Security* → *Low* → *Submit*).

Partie A — Injection SQL

Module **SQL Injection** de DVWA. Dans le champ *User ID* :

1. Testez d'abord une valeur **normale** : tapez `1` puis *Submit*.
2. Testez ensuite la **charge d'injection** :

`1' OR '1'='1`

À compléter

- Résultat avec `1` (combien de lignes / quelles infos ?) :

- Résultat avec la charge `1' OR '1'='1` :

- **Expliquez avec vos propres mots** ce qui s'est passé (aidez-vous du cours § 2.4) :

Partie B — XSS (reflected)

Module **XSS (Reflected)** de DVWA. Dans le champ de saisie, injectez :

```
<script>alert('test')</script>
```

- Que se passe-t-il à l'écran ?

- Pourquoi est-ce dangereux dans un vrai site (voir cours § 2.5) ?

Fiche de vulnérabilité n° 1 (à remplir — modèle réutilisable)

Champ	À compléter
Nom de la vulnérabilité	
Description (1-2 phrases)	
Étapes de reproduction	
Preuve (n° de capture d'écran)	
Impact (sur la triade CIA ?)	
Remédiation proposée	

TP4 — Brute force avec Hydra (≈ 20 min)

Objectif : montrer qu'un mot de passe faible est deviné automatiquement en quelques instants.

Consignes pas-à-pas

Module **Brute Force** de DVWA (niveau Low). Dans un terminal Kali :

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt <IP_CIBLE> \
http-get-form "/dvwa/vulnerabilities/
brute/:username=^USER^&password=^PASS^&Login=Login:F=Username and/or password
incorrect"
```

💡 **Astuce** — `-l admin` fixe l'identifiant, `-P rockyou.txt` fournit la liste de mots de passe à essayer, la partie `F=...` indique à Hydra le message affiché **en cas d'échec** (pour reconnaître le succès). Si `rockyou.txt` est compressé, décompressez-le : `sudo gunzip /usr/share/wordlists/rockyou.txt.gz`.

À compléter

- **Mot de passe trouvé** :
- **Temps approximatif** :
- Citez **2 protections** efficaces contre le brute force (cours § 2.6) :
 1.
 2.

Fiche de vulnérabilité n° 2 (même modèle)

Champ	À compléter
Nom de la vulnérabilité	
Description (1-2 phrases)	
Étapes de reproduction	
Preuve (n° de capture d'écran)	
Impact (sur la triade CIA ?)	
Remédiation proposée	

TP5 — AB Testing en Python (≈ 75 min)

Objectif : mener un test A/B de bout en bout et interpréter le résultat.

💡 **À faire** — Ouvrez **Jupyter Lab** puis le notebook `notebook_abtest.ipynb`. Le code est déjà là (avec quelques trous à compléter) ; ce cahier sert à **noter vos résultats et vos conclusions**.

Étape 1 — Génération des données simulées

Deux groupes de 5 000 visiteurs : A (contrôle, ~10 %) et B (variante, ~12 %).
Exécutez la cellule.

- Le tirage est-il aléatoire ou fixé ? (indice : `np.random.seed`)

Étape 2 — Statistiques descriptives

Exécutez le calcul des taux et le graphique.

- Taux groupe A : _____ % Taux groupe B : _____ %
- L'écart brut observé (B – A) : _____ points

Étape 3 — Test de significativité (test Z sur proportions)

- z-statistique : _____
- p-value : _____
- **Décision** — rejette-t-on H_0 ? (entourez) : **OUI** / **NON**
- Que signifie cette décision **en français** ?

💡 **Expérience à mener** — Dans le notebook, **réduisez** la taille des échantillons (ex. `n_a = n_b = 200`) puis relancez. La p-value augmente-t-elle ou diminue-t-elle ? _____ Que conclure sur le lien **taille d'échantillon** [?] **capacité à détecter un écart** ?

Étape 4 — Intervalles de confiance à 95 %

- **IC 95 % groupe A** : [_____ ; _____]
- **IC 95 % groupe B** : [_____ ; _____]
- Les deux intervalles se chevauchent-ils ? (entourez) : **OUI** / **NON** — qu'en déduire ? _____

Étape 5 — Exercice en autonomie

Chargez le second jeu de données (`ab_test_exercice.csv`), écart plus faible : ~10 % vs ~10,5 %) et refaites le test **seuls**.

- **p-value obtenue** :
- **Conclusion en UNE phrase** (« Le résultat est / n'est pas significatif car... ») :

Ce que vous aurez produit aujourd'hui

Votre trace de la journée (checklist du binôme)

☐

Fiche de reconnaissance réseau (TP1) complétée : ports et services de la cible.

☐

2 fiches de vulnérabilité minimum (TP3 SQLi/XSS et TP4 brute force), avec preuve et remédiation.

☐

Notebook A/B testing complété et enregistré, avec la **conclusion écrite en une phrase** (Étape 5).

☐

Ce cahier complété, avec les noms du binôme.

Bravo ! Vous avez mené votre premier pentest encadré et votre premier test A/B. Conservez ce cahier : c'est la trace de vos premières compétences en cyber et en data.